

PLANEA REPRESENTACIONES VIAJES Y EVENTOS S.A.S.

NIT 900.546.983 — Viaja América

PROCEDIMIENTO DE AUDITORÍA Y CONTROL DEL PROGRAMA DE PROTECCIÓN DE DATOS PERSONALES

Código	Versión	Fecha de aprobación	Aprobado por
PR-AUD-01	1.0	25 de septiembre de 2026	Representante Legal

1. Objetivo

Verificar de forma periódica y documentada que la Política de Tratamiento de Datos Personales (PTDP-01) y las medidas técnicas, administrativas, físicas y de seguridad del personal se cumplen y son eficaces, conforme al principio de Responsabilidad Demostrada (artículos 2.2.2.25.6.1 y 2.2.2.25.6.2 del Decreto 1074 de 2015) y a la Guía para la implementación del principio de responsabilidad demostrada (Accountability) de la SIC.

2. Alcance

Todas las bases de datos, procesos, sistemas, archivos físicos, colaboradores y proveedores que traten datos personales en la Compañía.

3. Responsables

- **Oficial de Protección de Datos (Norma Consuelo Linares Buitrago):** planea y ejecuta las revisiones internas, consolida hallazgos y hace seguimiento a los planes de acción.
- **Representante Legal:** aprueba el programa anual, recibe el informe y asigna recursos.
- **Auditor independiente (opcional):** revisión externa cada dos años o cuando lo exija un cliente.

4. Programa y periodicidad

Actividad	Periodicidad	Evidencia
Revisión de accesos de usuarios a correo, plataformas de reserva, carpetas compartidas (altas, bajas, permisos)	Trimestral	Lista de usuarios revisada y firmada
Verificación del registro de PQR de Titulares y cumplimiento de términos legales	Trimestral	Registro de PQR
Revisión del registro de incidentes y estado de planes de mejora	Trimestral	Registro de incidentes
Auditoría interna integral de	Semestral	Informe de auditoría interna

Actividad	Periodicidad	Evidencia
protección de datos (lista de verificación, sección 6)		
Verificación de copias de seguridad y prueba de restauración	Semestral	Acta de prueba
Actualización del inventario de bases de datos y, cuando aplique, del RNBD	Anual (y ante cambios sustanciales)	Inventario actualizado / constancia RNBD
Capacitación del personal en protección de datos personales y seguridad de la información	Anual + inducción de nuevos colaboradores	Listas de asistencia y evaluación
Revisión de contratos y cláusulas de protección de datos con proveedores/Encargados	Anual	Matriz de proveedores
Simulacro del procedimiento de incidentes (PR-IDP-01)	Anual	Informe del simulacro
Revisión y actualización de la Política y procedimientos	Anual	Control de cambios
Informe anual del programa al Representante Legal	Anual	Informe firmado

5. Metodología

1. **Planeación:** en enero de cada año el Oficial elabora el cronograma anual (Anexo B) y lo aprueba el Representante Legal.
2. **Ejecución:** se aplica la lista de verificación de la sección 6 mediante entrevistas, revisión documental, revisión de configuraciones y muestreo de registros.
3. **Hallazgos:** cada incumplimiento se clasifica como No conformidad mayor, No conformidad menor u Oportunidad de mejora.
4. **Plan de acción:** para cada hallazgo se define acción correctiva, responsable y fecha de cierre (máximo 30 días para no conformidades mayores y 90 días para menores).
5. **Seguimiento:** el Oficial verifica el cierre en la siguiente revisión trimestral.
6. **Informe:** los resultados se consolidan en el informe semestral y anual, que se conserva como evidencia de Responsabilidad Demostrada por mínimo 5 años.

6. Lista de verificación de la auditoría interna

#	Control	Cumple (S/N)	Observación
A	Medidas administrativas / organizacionales		
A1	La Política está aprobada, vigente y publicada en el sitio web.		
A2	El Oficial de Protección de Datos está designado formalmente (ODP-01).		
A3	Existe inventario actualizado de bases de datos y finalidades.		
A4	Se obtiene y conserva la autorización de los Titulares en todos los canales (web, WhatsApp, correo, formularios).		
A5	Consultas y reclamos se responden en 10 y 15 días hábiles respectivamente.		
A6	Contratos con proveedores/Encargados incluyen cláusulas de protección de datos.		
A7	RNBD registrado y actualizado (si aplica).		
B	Medidas técnicas		
B1	Cuentas individuales; sin usuarios compartidos; contraseñas robustas y doble factor en correo y plataformas críticas.		
B2	Accesos retirados el mismo día del retiro de un colaborador.		
B3	Sitio web y plataformas con HTTPS/TLS vigente.		
B4	Equipos con antivirus, actualizaciones y bloqueo de pantalla.		
B5	Copias de seguridad realizadas y probadas.		
C	Medidas físicas		
C1	Documentos físicos con datos personales (pasaportes, formularios) guardados bajo llave.		
C2	Destrucción segura de documentos que ya no se requieren.		
C3	Política de escritorio y pantalla limpios.		
D	Seguridad del personal		
D1	Colaboradores y contratistas firmaron acuerdo de confidencialidad.		
D2	Capacitación anual realizada y registrada.		

#	Control	Cumple (S/N)	Observación
D3	Inducción en protección de datos a nuevos colaboradores.		
E	Gestión de incidentes		
E1	Registro de incidentes al día; incidentes reportados a la SIC en plazo.		
E2	Simulacro anual ejecutado.		

7. Indicadores

Indicador	Meta
% de PQR de Titulares respondidas dentro del término legal	100 %
% de colaboradores capacitados en el año	100 %
% de hallazgos cerrados en el plazo	≥ 90 %
% de incidentes reportados a la SIC en plazo	100 %
% de proveedores con cláusula de protección de datos	100 %

Anexo B. Cronograma inicial

Actividad	Fecha
Adopción de la Política, designación del Oficial y procedimientos	25 de septiembre de 2026
Divulgación y capacitación inicial al personal	Octubre de 2026
Primera revisión trimestral de accesos, PQR e incidentes	Diciembre de 2026
Primera auditoría interna integral	Marzo de 2027
Simulacro de incidente	Mayo de 2027
Segunda auditoría interna e informe anual	Septiembre de 2027

Control de cambios

Versión	Fecha	Descripción del cambio
1.0	25 de septiembre de 2026	Emisión inicial del documento.

Aprobación



Carlos Enrique Bonilla Sánchez

C.C. 80.231.516

Representante Legal — PLANEA REPRESENTACIONES VIAJES Y EVENTOS S.A.S.



Norma Consuelo Linares Buitrago

Directora de Seguridad de la Información (CISO) — Oficial de Protección de Datos Personales